

Security+ 1.3 · Change Management

Mestre CyberSec — PDF baseado na aula do Professor Messer · 1.3 — Change Management (11:22) · [vídeo original](#) · [YouTube](#)

Mudança em produção com segurança: documentar a requisição de mudança (RFC), checar risco, aprovar (CAB — Change Advisory Board), testar em ambiente isolado, agendar janela, ter plano de ROLLBACK, avisar afetados; executar, verificar, documentar. Emergency change: menos processo, mas DOCUMENTA depois.

💡 Highlights que a prova cobra

- Rollback plan: o que fazer se der errado — SEM isso, não aprova
- Emergency change: CAB rápido, ainda documentado
- Todo change passa por ambiente de TESTE antes de produção

🎯 Dicas de prova

- 'requires rollback plan and testing before deployment' = change management
- 'emergency change bypasses some approvals' = ainda precisa de documentação

Cenário clássico: Cenário típico: 'aplicação precisa de update no servidor de produção; o técnico precisa testar antes e ter rollback' → change management.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. RTO (Recovery Time Objective) mede:
 - A) Quanto DADO você aceita perder
 - B) Quanto TEMPO o serviço pode ficar fora
 - C) O custo do incidente
 - D) O número de usuários afetados

2. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A)** Instalar, Atualizar, Testar, Auditar, Arquivar
- B)** Identificar, Proteger, Detectar, Responder, Recuperar
- C)** Planejar, Fazer, Checar, Agir, Revisar
- D)** Prevenir, Punir, Prever, Provar, Publicar

3. ISO/IEC 27001 é:

- A)** A norma INTERNACIONAL de gestão de segurança da informação (SGSI)
- B)** Uma lei dos EUA
- C)** Um tipo de firewall
- D)** Um scanner de vulnerabilidade

4. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Rollback plan: o que fazer se der errado — SEM isso, não aprova'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Rollback plan: o que fazer se der errado — SEM isso, não aprova...

5. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Emergency change: CAB rápido, ainda documentado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Emergency change: CAB rápido, ainda documentado...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Todo change passa por ambiente de TESTE antes de produção'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Todo change passa por ambiente de TESTE antes de produção...

7. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'requires rollback plan and testing before deployment' = change management'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'requires rollback plan and testing before deployment' = change management...

8. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'emergency change bypasses some approvals' = ainda precisa de documentação'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'emergency change bypasses some approvals' = ainda precisa de documentação...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'aplicação precisa de update no servidor de produção; o técnico precisa testar antes e ter rollback' → change management.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário típico: 'aplicação precisa de update no servidor de produção; o téc...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Change Management): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.3), um analista avalia o seguinte requisito técnico: 'Rollback plan: o que fazer se der errado — SEM isso, não aprova'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Rollback plan: o que fazer se der errado — SEM isso, não aprova...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) B — Quanto TEMPO o serviço pode ficar fora.** RTO = tempo máximo aceitável de indisponibilidade (quão rápido tem que voltar). Não confundir com RPO (quanto dado pode perder).
- 2) B — Identificar, Proteger, Detectar, Responder, Recuperar.** NIST CSF = Identify, Protect, Detect, Respond, Recover. É o 'checklist mestre' citado em quase toda vaga. (A versão 2.0/2024 somou uma 6ª função, Govern — mas o SY0-701 ainda cobra as 5.) Decorar essas dá ponto fácil na
- 3) A — A norma INTERNACIONAL de gestão de segurança da informação (SGSI).** ISO 27001 = padrão internacional pra montar um Sistema de Gestão de Segurança da Informação (SGSI). Contrato B2B grande exige. A 27701 é a extensão de privacidade (LGPD/GDPR).
- 4) D — Implementar a solução correspondente: Rollback plan: o que fazer se der errado —.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Rollback plan: o que fazer se der errado — SEM isso, não aprova. As demais alternativas configuram violações graves
- 5) C — Implementar a solução correspondente: Emergency change: CAB rápido, ainda docume.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Emergency change: CAB rápido, ainda documentado. As demais alternativas configuram violações graves de conformidade
- 6) D — Implementar a solução correspondente: Todo change passa por ambiente de TESTE an.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Todo change passa por ambiente de TESTE antes de produção. As demais alternativas configuram violações graves de co
- 7) D — Implementar a solução correspondente: 'requires rollback plan and testing before.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): 'requires rollback plan and testing before deployment' = change management. As demais alternativas configuram viola
- 8) A — Implementar a solução correspondente: 'emergency change bypasses some approvals'.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): 'emergency change bypasses some approvals' = ainda precisa de documentação. As demais alternativas configuram viola
- 9) C — Implementar a solução correspondente: Cenário típico: 'aplicação precisa de upda.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Cenário típico: 'aplicação precisa de update no servidor de produção; o técnico precisa testar antes e ter rollback
- 10) B — Implementar a solução correspondente: Rollback plan: o que fazer se der errado —.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.3 (Change Management): Rollback plan: o que fazer se der errado — SEM isso, não aprova. As demais alternativas configuram violações graves

